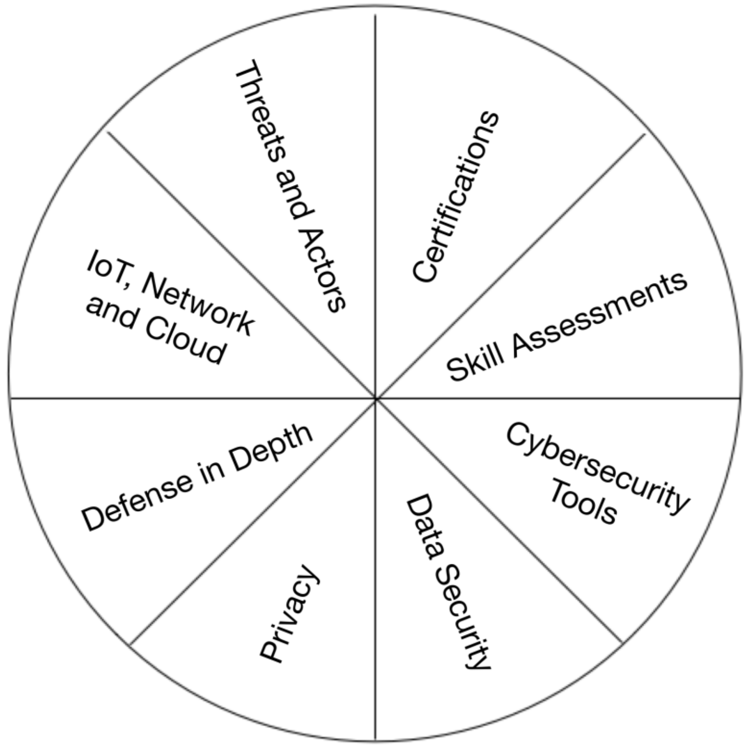
IoT Compliance Monitoring Program

- Executive oversight
- Policies, procedures, and documentation
- Training and education
  - Skills assessments
    - IoT data security
    - IoT privacy
    - Safety procedures for IoT systems
    - IoT-specific security tools (scanners and so on)
  - Cybersecurity tools
  - Data security
  - Defense in depth
  - Privacy
  - The IoT, networks, and the cloud
  - Threats/attacks
  - Certifications
- Testing



Russel & Van Duren: “Practical Internet of Things Security”, 2nd edition, Packt Publishing, 2019

IoT Compliance Monitoring Program

Faculty of Computer Science and Mathematics

- Internal compliance monitoring
  - Install/update sensors
  - Automated search for flaws
  - Collect results
  - Triage
  - Bug fixes
  - Progress reports
  - System design updates
  - System implementation
- Periodic risk assessments
  - Black-box testing
    - Physical security evaluation
    - Firmware/software update process analysis
    - Interface analysis
    - Wireless security evaluation
    - Configuration security evaluation
    - Mobile application evaluation
    - Cloud security analysis (web service security)

IoT Compliance Monitoring Program

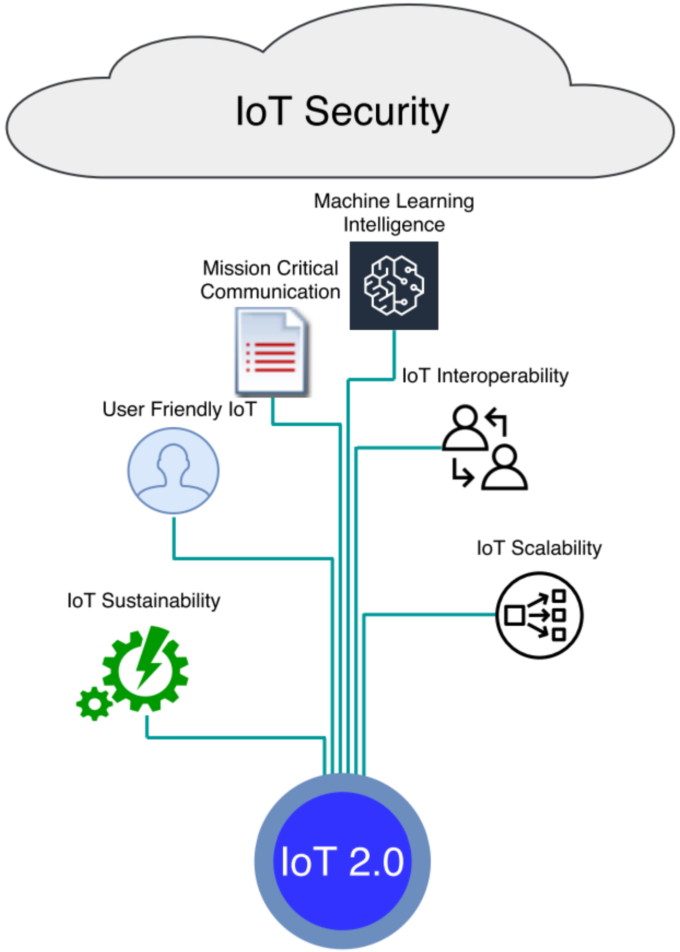
- Periodic risk assessments
  - White-box assessments
    - Staff interviews
    - Reverse-engineering
    - Hardware component analysis
    - Code analysis
    - System design and configuration documentation reviews
    - Fault and attack tree analysis
  - Fuzz testing
    - Power-on/power-off sequences/state changes
    - Protocol tag/length/value fields
    - Header processing
    - Data-validation attacks
    - Integrate with analyser
- Examining existing compliance standards, support for the IoT
- Remediation planning

Governmental-Level attacks

- Performed by government-level/state-level (or tech-giant-level) agencies
- Practically impossible to avoid, due to extremely high level of available
    - Resources
    - Time
    - Effort
- Such attacks become more and more frequent
- Such attacks are bound to also affect the IoT significantly
- Resilience and prevention measures against them are required

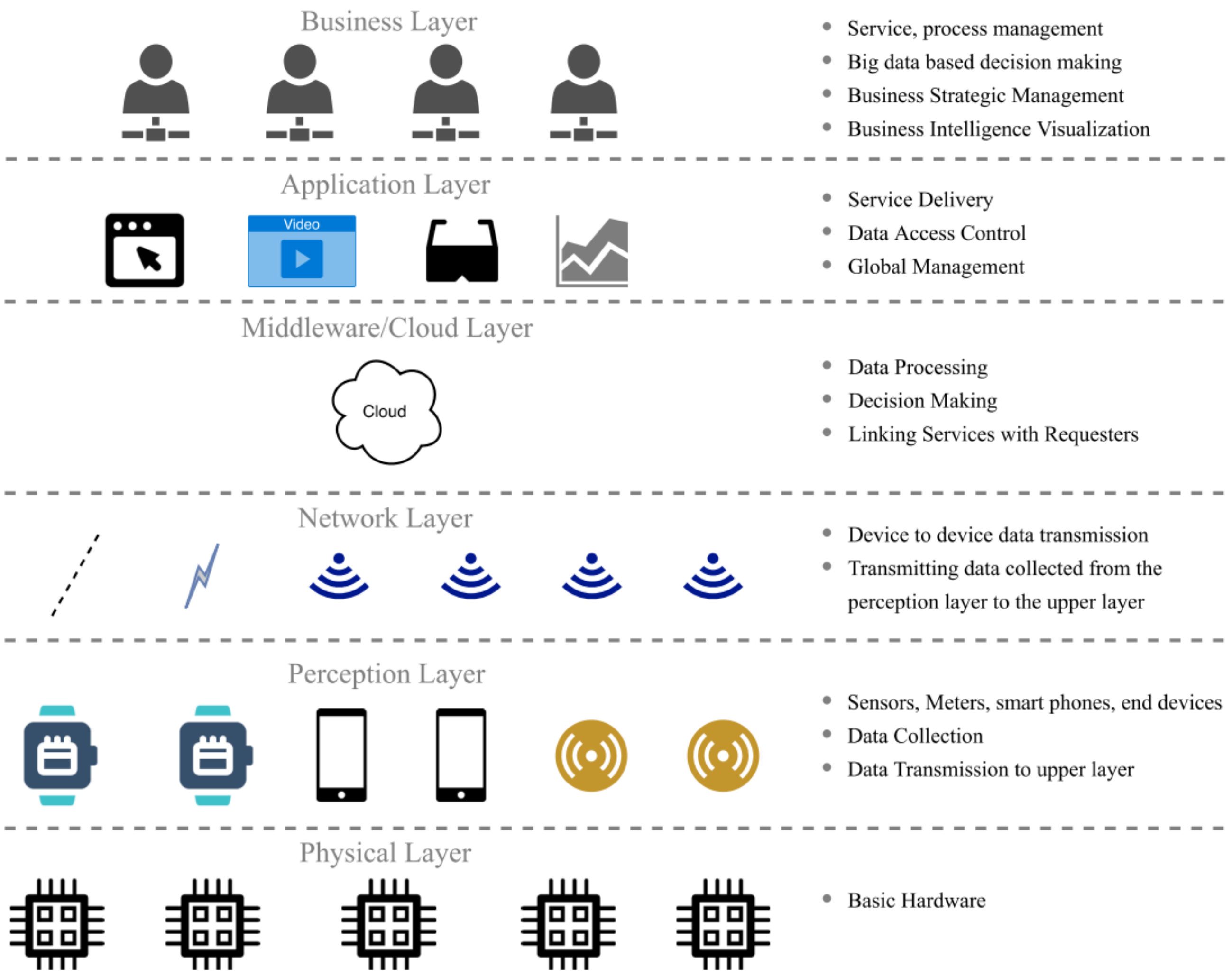
IoT 2.0

- A concept that connects the Internet of Things (IoT) to other innovative technologies and concepts, such as 5G/6G, machine learning and artificial intelligence, edge computing, Industry 4.0/5.0, the blockchain, post-CMOS technologies, as well as user-friendliness, sustainability, interoperability, scalability, and security.



Zhou, I., Makhdoom, I., Shariati, N., Raza, M. A., Keshavarz, R., Lipman, J., Abolhasan, M., Jamalipour, A. (2021). Internet of Things 2.0: Concepts, Applications, and Future Directions. IEEE Access, 9, 70961–71012.

Conventional IoT Architecture



Zhou, I., Makhdoom, I., Shariati, N., Raza, M. A., Keshavarz, R., Lipman, J., Abolhasan, M., Jamalipour, A. (2021). Internet of Things 2.0: Concepts, Applications, and Future Directions. IEEE Access, 9, 70961–71012.

Recent Layered IoT Architectures

Architectures						Functions
					Security	1. Data Encryption. 2. User Authentication. 3. Access Control. 4. Protection over all layers.
					Collaboration/ Process	1. Collaboration platform for multiple personnels
		Cloud Service	Application	Management	Application	1. Software interfaces to interact with lower levels. 2. Services interfaces between lower levels and users. 3. Control interface for lower level facilities. 4. Business Intelligence. 5. High Level Decision Making
Cloud	Cloud	Cloud	Cloud Computing	Server and Storage	Management Service	1. Complex Data Storage. 2. Complex Centralized Processing. 3. Training machine learning models for the cloud and the fog/edge layers. 4. Hosting Complex Machine Learning Model. 5. Basis for High Level Decision Making. 6. Multi-purpose servers. 7. Network management.
	Network Core			Core Network		1. Gateway to the cloud layer. 2. Interfaces to the fog/edge layer. 3. Linkage between the cloud and fog/edge layers.
					Data Storage	1. Storing huge data volume from the edge/fog layer.
Fog/Edge	Fog/Edge	Fog	Data Domain	Edge Network	Edge/Fog Computing	1. Connecting the end devices with the cloud. 2. Gathering data from the lower layer. 3. Basic Data Analytics. 4. Medium Data Analytics (e.g. Image Recognition) 5. Passing heavy analytical tasks to the cloud. 6. Running low level machine learning model. 7. Prepare data as inputs for high level analytics. 8. Data Storage. 9. Low level decision making. 10. Real time services
			Network Domain		Communication	1. Connects lower layer end devices to the upper layer. 2. Management of time sequence sensitive data. 3. D2D Communication. 4. Advanced Spectrum Sharing and Interference Management.
IoT End Devices	IoT End Devices	Edge Client	Device Domain	End User	Physical Devices	1. Collecting data from the environment. 2. Transfer data to the upper layer. 3. Accept instructions from the upper layer.
(Peralta et al. 2017; Carnevale et al. 2018; Li, Ota & Dong 2018)	(Shahzadi et al. 2019)	(Kalatzis et al. 2018)	(Chen et al. 2018)	(Guo et al. 2018)	(Rahimi, Zibaeenejad & Safavi 2018)	

Zhou, I., Makhdoom, I., Shariati, N., Raza, M. A., Keshavarz, R., Lipman, J., Abolhasan, M., Jamalipour, A. (2021). Internet of Things 2.0: Concepts, Applications, and Future Directions. IEEE Access, 9, 70961–71012.

Scalability and Interoperability

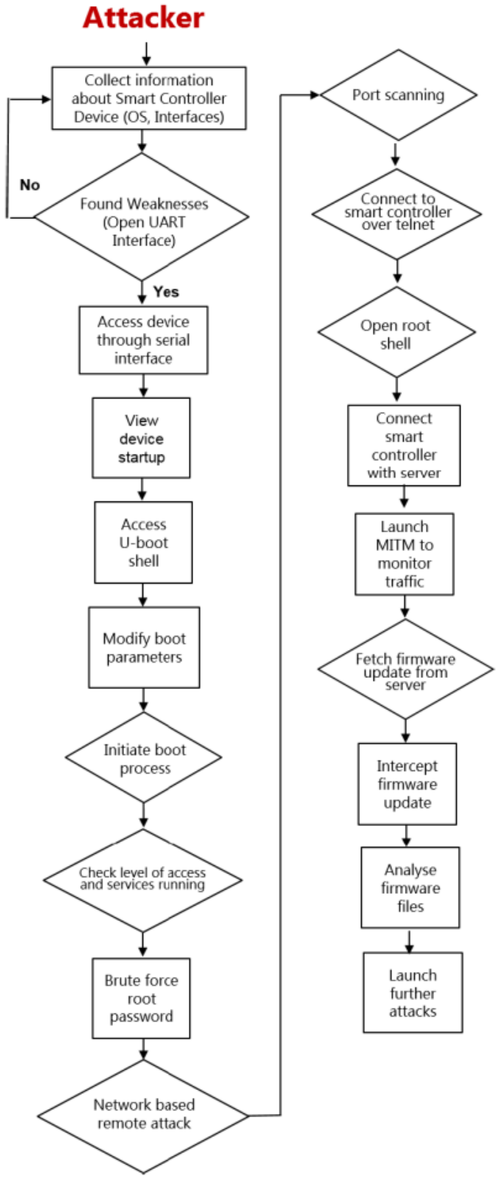
Type of Scalability	Definition
Hardware Scalability	The ability of a piece of hardware to be extended to cope with different environmental, network and service requirements.
Network Scalability	The ability to dynamically scale resources up and down to process the incoming IoT traffic.
Service Scalability	The ability to incorporate new services into the existing IoT system.

Type of Interoperability	Definition
Device Interoperability	The exchange of information between heterogeneous devices and heterogenous communication protocols;The ability to integrate new devices into different IoT platforms.
Network Interoperability	Interact between different system accounting routing, resource optimization, security, quality of service and mobility.
Syntactical Interoperability	Interoperation of data structure in exchanged information.
Semantic Interoperability	Descriptions or understandings of resource, operational procedures, data models and information models between different entities.
Platform Interoperability	Interoperability required for barriers created by different IoT stacks consist of different operating systems, programming languages, data structures, architectures and access mechanisms for things and data.

Tier	Base Station/Devices	Communication Method
Space	Low-Earth orbit, medium-Earth-orbit, and geostationary satellites	mm-wave and laser communication between satellites.
Air	Flying base stations (UAV), floating base stations	Low frequency, microwave, and mm-wave bands.
Terrestrial	Ultra-dense network with small base stations	Low frequency, microwave, mm-wave, and THz bands.
Underwater	Underwater military and commercial devices	Acoustic and laser communications.

Zhou, I., Makhdoom, I., Shariati, N., Raza, M. A., Keshavarz, R., Lipman, J., Abolhasan, M., Jamalipour, A. (2021). Internet of Things 2.0: Concepts, Applications, and Future Directions. IEEE Access, 9, 70961–71012.

Example Device Compromise Attack

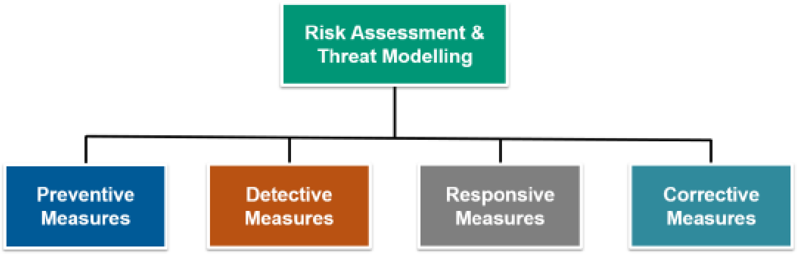


Zhou, I., Makhdoom, I., Shariati, N., Raza, M. A., Keshavarz, R., Lipman, J., Abolhasan, M., Jamalipour, A. (2021). Internet of Things 2.0: Concepts, Applications, and Future Directions. IEEE Access, 9, 70961–71012.

Defence-in-Depth Approach

IoT Layer	Threats
Physical layer	Eavesdropping
	Hardware failure
	Malicious data injection
	MITM
	Sybil attack
	Loss of power
	Information disclosure
	Side-channel attacks
	Device compromise and node cloning
	Invasive/semi-invasive intrusions
Network layer	Unfairness and impersonation attacks
	Sybil attack
	Interrogation attacks
	Channel congestion and collision attacks
	Battery exhaustion attacks
	Hello flood attacks
	Selective forwarding attack
	Wormhole and blackhole attacks
	Storage attacks
	CSMA attack
	PANId conflicts
	MITM, eavesdropping and spoofing attacks
	Remote device compromise
	Node replication
	Insertion of rogue devices
Fog/Edge layer	Issues concerning device authentication
	Lack of trust mechanism
	Threats to IoT device integrity
	Vulnerability to insider and external attacks
Cloud layer	Single point of failure
	Data manipulation
	Threats to the availability of cloud services
	Risk of unauthorized data sharing
Application layer	Information disclosure
	Elevation of privileges and data tampering
	Threat of botnets
	Code substitution or code extension attacks
	Injection flaws in SQL/noSQL Databases, OS and LDAP
	Session hijacking
	Security misconfiguration
	XSS
	Plain-text recovery attacks
	Resource constraints
Business layer	Unauthorized sharing of data/information
	Threats to user privacy

Zhou, I., Makhdoom, I., Shariati, N., Raza, M. A., Keshavarz, R., Lipman, J., Abolhasan, M., Jamalipour, A. (2021). Internet of Things 2.0: Concepts, Applications, and Future Directions. IEEE Access, 9, 70961–71012.



Defense Category	Security Measures
Risk assessment	Identify critical assets
	Vulnerability assessment
	Risk treatment and mitigation strategy
Protective measures	Security by design
	Identity management
	Tamper-proofing
	Use of pseudonymous identities
	Identity-based authenticated encryption and mutual authentication
	Homomorphic encryption
	Blockchain technology
	Role-based access control
	Secure remote access
	Key management
	Network segmentation
	SDN
	Self-encrypting devices
	Security training and awareness
Detective measures	Secure log management
	Network security analysis
	Edge security analysis
	Network-level security measures
	Device attestation
	Penetration testing and vulnerability assessment
Responsive measures	Establishment of CERT
	Preparation of incident response plan
Corrective measures	Self recovery of nodes
	Remote attestation
	Device replacement/reconfiguration
	Review and updating security policies